



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-45247 Mirasvit Full Page Cache Warmer Deserialization of Untrusted Data Vulnerability

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-03
Version	1.1
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-45247 Mirasvit Full Page Cache Warmer Deserialization of Untrusted Data Vulnerability - CVE / Vulnerability Threat Intelligence Report

Published: 2026-06-03 | TLP:CLEAR | Version: 1.1 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

CVE-2026-45247 Mirasvit Full Page Cache Warmer Deserialization of Untrusted Data Vulnerability

1. Executive Summary

CVE-2026-45247 is a critical unauthenticated remote code execution vulnerability in Mirasvit Full Page Cache Warmer for Magento 2. The flaw is a PHP object injection issue caused by unsafe deserialization of attacker-controlled data from the `CacheWarmer` cookie. Both the CVE record and NVD describe the impact as arbitrary code execution on the server without prior authentication.

Operationally, this is a high-priority internet-facing application risk. The vulnerable code path runs on ordinary storefront requests, not only on administrative or maintenance interfaces, so exposed Magento and Adobe Commerce storefronts running the Mirasvit extension can be targeted through normal web traffic. Sansec's technical write-up says the issue can be reached on any storefront page with a single crafted cookie and that a suitable gadget chain can turn the object injection into remote code execution.

CISA added the issue to the Known Exploited Vulnerabilities catalog on 2026-06-03, indicating active exploitation in the wild. Mirasvit released a fix in version 1.11.12 on 2026-05-25. Defenders should treat this as a patch-now web-application exposure, validate whether the extension is present directly or through bundled Mirasvit packages, and review for signs of post-exploitation such as webshell placement or unexpected PHP files.

Confirmed facts:

- CVE ID: CVE-2026-45247
- Vendor: Mirasvit
- Product: Full Page Cache Warmer for Magento 2
- Vulnerability class: PHP object injection / deserialization of untrusted data
- CWE: CWE-502
- Impact: Unauthenticated remote code execution
- Fixed version: 1.11.12 and later
- KEV date added: 2026-06-03
- CVSS v3.1: 9.8 Critical
- CVSS v4.0: 9.3 Critical

Analyst assessment:

- Prioritize all internet-facing Magento and Adobe Commerce storefronts using Mirasvit extensions.
- Assume opportunistic exploitation is plausible wherever the vulnerable module is exposed to customer traffic.
- If vulnerable stores cannot be patched immediately, use compensating controls only as a short-lived emergency measure and begin compromise assessment in parallel.

2. Vulnerability Metadata

Field	Value
CNA title	Mirasvit Cache Warmer for Magento < 1.11.12 PHP Object Injection
Published by CNA	2026-05-26
Last updated in CVE record at review time	2026-06-04
Vulnerable product	Mirasvit Full Page Cache Warmer for Magento 2
Affected versions	versions earlier than 1.11.12
Attack vector	Network

Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged in CVSS v3.1
Confidentiality / Integrity / Availability impact	High / High / High
Fixed version called out by vendor	1.11.12

Key metadata: Why the issue matters:

- The vulnerable input is carried in a cookie and processed on storefront requests.
- The target surface is often public-facing e-commerce infrastructure.
- The extension may be present indirectly because it is bundled with other Mirasvit packages.

3. Source Review & Confidence

Primary-source basis: Secondary-source basis:

Source	Contribution	Confidence
Primary source	CISA KEV lists CVE-2026-45247 for Mirasvit Full Page Cache Warmer, added on 2026-06-03 with required action to apply ven	High confidence. Authoritative exploitation-status source for KEV inclusion and required-action lang
Primary source	The CVE record says Mirasvit Full Page Cache Warmer for Magento 2 before 1.11.12 contains a PHP object injection vulnera	High confidence. Canonical CVE description and affected-version range.
Reviewed source	NVD mirrors the core CVE description and shows critical severity, including CVSS v3.1 9.8 from the CNA and CVSS v4.0 9.3	High confidence for normalized vulnerability metadata and scoring context.
Reviewed source	Mirasvit's changelog states that version 1.11.12, released 2026-05-25, fixed a PHP object injection vulnerability in ses	High confidence. Authoritative vendor fix statement.
Reviewed source	Sansec found the issue, describes it as unauthenticated PHP object injection reachable through any storefront request, n	High confidence for technical mechanics and practical detection cues; medium confidence for rough pr
Reviewed source	Imperva characterizes the issue as a critical unauthenticated RCE in a Magento extension and frames compensating control	Medium confidence. Useful secondary defensive context but not the canonical vulnerability source.

Confidence assessment:

4. Vulnerability Details

The vulnerable behavior centers on how the extension handles the `CacheWarmer` cookie. According to the CVE description and Sansec's write-up, the extension deserializes attacker-controlled data with PHP's native `unserialize()` function and does

not sufficiently restrict the classes that may be instantiated. In PHP applications with available gadget chains, that pattern can permit object injection and arbitrary code execution.

Sansec explains that the extension uses the cookie to reconstruct visitor state while warming cache variations such as currency or customer-group context. The defensive problem is that the relevant plugin runs on every storefront request, so the risky deserialization path is reachable through ordinary web requests instead of a tightly constrained maintenance channel.

Practical implications:

- No authentication is required.
- The attack can be delivered over normal HTTP(S) requests to storefront pages.
- Successful exploitation may result in arbitrary PHP execution and follow-on persistence.
- The issue is especially urgent for merchants with direct internet exposure and limited file-integrity monitoring.

5. Attack Scenarios

Scenario 1: Direct exploitation of a public storefront

- An attacker identifies a Magento or Adobe Commerce storefront using a vulnerable Mirasvit Cache Warmer version.
- The attacker sends a crafted `CacheWarmer` cookie to a normal storefront endpoint.
- The vulnerable deserialization path reconstructs attacker-controlled objects and triggers code execution.

Scenario 2: Opportunistic scanning after KEV listing

- Threat actors or botnets enumerate public Magento storefronts and test for exploitation signatures.
- Vulnerable instances are exploited in bulk for webshell placement, skimmer deployment, or staging further payloads.
- Defenders may first notice the incident through anomalous requests or new PHP files in web-accessible directories.

Scenario 3: Indirect exposure through bundled packages

- A merchant does not realize the Cache Warmer module is installed because it arrived with another Mirasvit package.
- Standard patch checks miss the extension.
- The store remains vulnerable even though defenders believe no cache-warmer component is in use.

6. Threat Landscape & Exploitation Status

CISA added CVE-2026-45247 to KEV on 2026-06-03. That is the strongest public signal available in this review set that exploitation has moved beyond a theoretical or lab-only condition. KEV inclusion should drive emergency patching and retrospective hunting, especially for internet-facing storefronts that process customer traffic continuously.

Sansec reported that it found the vulnerability on 2026-04-24, deployed protection for its managed customers that same day, notified Mirasvit on 2026-05-21, and published the advisory on 2026-05-26 after the vendor released version 1.11.12 on 2026-05-25. That timeline indicates a short disclosure-to-patch window and supports the view that defenders had limited time before public weaponization risk increased.

CISA's KEV entry lists `knownRansomwareCampaignUse` as `Unknown`, so this review does not tie the flaw to a named ransomware operation. That should not reduce urgency: unauthenticated RCE against an e-commerce application can lead to payment skimming, credential theft, webshell persistence, data theft, and staging for follow-on intrusion.

7. Affected Products and Exposure

Affected products:

- Mirasvit Full Page Cache Warmer for Magento 2 before version 1.11.12
- Storefronts where the extension is installed directly or bundled through other Mirasvit packages

Highest-priority exposure classes:

- Internet-facing Magento storefronts
- Adobe Commerce deployments with public product or checkout pages
- Multi-store environments where one shared extension package spans several storefronts
- Stores without centralized web-server, PHP, and file-integrity monitoring

Immediate scoping questions:

- Which stores have `mirasvit/module-cache-warmer` installed at versions earlier than 1.11.12?
- Which environments expose storefront traffic directly to the internet?
- Which stores lack recent patch and extension-inventory validation?
- Which systems show recent changes in web-accessible PHP files or suspicious cron jobs?

8. Mitigation and Workarounds

Immediate actions:

- Upgrade Mirasvit Full Page Cache Warmer to version 1.11.12 or later.
- Verify whether the module is present as a direct installation or a bundled dependency.
- Review web-accessible directories such as `pub/` for unexpected PHP files, loaders, or modified templates.
- Preserve relevant web, application, and EDR telemetry before extensive cleanup if compromise is suspected.

Short-term hardening:

- Apply WAF rules that can inspect for suspicious `CacheWarmer` cookie patterns while patching is in progress.
- Restrict administrative access paths and deployment credentials for affected stores.
- Tighten monitoring around PHP process execution, file writes, and webroot changes.
- Re-scan the environment after patching to confirm no lingering malicious artifacts remain.

Workaround note:

- The authoritative fix is upgrading to version 1.11.12 or later.
- Compensating controls may buy time but should not be treated as complete remediation for a deserialization-based RCE.

9. Detection Engineering

Detection priorities: Sansec's high-value request indicator: Recommended telemetry: Practical analytic themes:

Signal	Telemetry Source	Analytic Goal
HTTP requests carrying suspicious `CacheWarmer` cookie values	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
Web requests followed by anomalous PHP process behavior or file writes	Application logs, service metrics, EDR / crash telemetry	Spot exploitation symptoms or instability
New or modified PHP files under web-accessible directories	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
Unexpected outbound connections or secondary payload retrieval after storefront requests	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
A `CacheWarmer` cookie value beginning with `CacheWarmer:` followed by base64 content starting with `Tz`, `Qz`, or `YT` is a strong indicator of an exploitation attempt because serialized PHP objects often encode with those prefixes.	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity

9.1 Detection Query

```
// Build and package provenance pivots for CVE-2026-45247 Mirasvit Full Page Cache Warmer
Deserialization of Untrusted Data Vulnerability
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_any ("go version", "go env", "pip show", "pip list", "syft", "grype",
```

```
"sbom")
| project Timestamp, DeviceName, InitiatingProcessAccountName, FileName, ProcessCommandLine
| order by Timestamp desc
```

9.2 Exposure / Triage Query

```
// Hunt for service instability or repeated process failures near affected build lineage
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ActionType has_any ("ProcessTerminated", "Crash", "ApplicationError") or ProcessCommandLine
has_any ("panic", "fatal error")
| project Timestamp, DeviceName, FileName, ProcessCommandLine, InitiatingProcessFileName
| order by Timestamp desc
```

10. Threat Hunting

Hunt objectives:

- Identify exposed stores running versions earlier than 1.11.12.
- Find suspicious `CacheWarmer` cookie usage in historical web logs.
- Look for evidence of webshell placement or unauthorized PHP file creation after 2026-04-24.
- Search for persistence or follow-on activity from compromised web applications.

Suggested hunt questions:

- Which storefront requests carried `CacheWarmer:` cookie values with serialized-object-like prefixes?
- Did any affected store show unusual file creation in `pub/`, media, cache, or temporary directories?
- Were there unexpected child processes from the web server or PHP runtime?
- Did any affected host initiate suspicious outbound traffic after anomalous storefront requests?

Useful local pivots:

- Web access logs filtered for `CacheWarmer` cookie presence
- Magento extension inventory and deployment records
- Recent filesystem changes to PHP, `.phtml`, `.phar`, or cron-related files
- EDR telemetry around shell spawns, download activity, or web-server account abuse

10.1 Hunt Query

```
// Hunt for service instability or repeated process failures near affected build lineage
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ActionType has_any ("ProcessTerminated", "Crash", "ApplicationError") or ProcessCommandLine
has_any ("panic", "fatal error")
| project Timestamp, DeviceName, FileName, ProcessCommandLine, InitiatingProcessFileName
| order by Timestamp desc
```

11. MITRE ATT&CK Mapping

Mapped ATT&CK techniques:

- T1190 - Exploit Public-Facing Application
- Rationale: The vulnerability is reached over normal storefront web traffic on a public-facing e-commerce application.
- T1505.003 - Server Software Component: Web Shell
- Rationale: Webshell placement is a realistic post-exploitation outcome for successful RCE on a Magento web tier and is an explicit hunting priority.

Interpretation:

- T1190 captures the initial access and execution path.
- T1505.003 captures a common persistence and follow-on objective defenders should check for even though a specific webshell family is not identified in the reviewed sources.

12. Validation / Lab Testing

Safe validation steps:

- Confirm installed extension versions on each storefront and verify they are at or above 1.11.12.
- Test log collection for `CacheWarmer` cookie visibility in a lab or staging environment.
- Validate that file-integrity monitoring alerts on unauthorized PHP file creation in web-accessible paths.
- Confirm WAF or reverse-proxy rules can surface or block suspicious cookie patterns without breaking legitimate cache-warmer traffic.

Recommended validation checklist:

1. Inventory all Magento and Adobe Commerce stores using Mirasvit extensions.
2. Confirm whether `mirasvit/module-cache-warmer` is installed directly or bundled.
3. Verify each affected store is upgraded to 1.11.12 or later.
4. Review web and application logs from 2026-04-24 forward for suspicious `CacheWarmer` cookie use.
5. Review `pub/` and other web-accessible directories for unexpected PHP files.
6. Confirm EDR or host telemetry is present for the web tier.
7. Run a post-patch compromise assessment before closing the incident window.

Do not test exploitation against production storefronts.

13. Recommended Actions Summary

Critical - Application / E-commerce - 24 hours Critical - SOC / IR - 24 hours High - Security Engineering - 24 to 48 hours
High - Platform / DevOps - 24 to 48 hours Medium - Vulnerability Management - 1 week If exploitation is suspected:

Priority	Owner	Action
Critical	Platform / Application Owners	Upgrade Mirasvit Full Page Cache Warmer to 1.11.12 or later on every affected store.
High	Security / Platform Owners	Verify whether the module is present through bundled Mirasvit packages as well as direct installs.
High	SOC / Detection Engineering	Hunt historical web logs for suspicious `CacheWarmer` cookie activity beginning 2026-04-24.
High	Security / Platform Owners	Review web-accessible directories for unauthorized PHP files, loaders, or cron persistence.
High	SOC / Detection Engineering	Add temporary WAF or reverse-proxy detections for suspicious `CacheWarmer` cookie patterns.
High	Security / Platform Owners	Confirm alerting on web-server child-process execution and unexpected outbound connections.

14. References

- CISA Known Exploited Vulnerabilities JSON feed
- https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json

- CISA Known Exploited Vulnerabilities catalog entry
- https://www.cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-45247
- CVE Program record for CVE-2026-45247
- <https://cveawg.mitre.org/api/cve/CVE-2026-45247>
- NVD CVE detail page
- <https://nvd.nist.gov/vuln/detail/CVE-2026-45247>
- Mirasvit changelog for Full Page Cache Warmer
- <https://mirasvit.com/package/changelog/?package=mirasvit/module-cache-warmer>
- Sansec technical advisory
- <https://sansec.io/research/mirasvit-cache-warmer-object-injection>
- Imperva advisory
- <https://www.imperva.com/blog/imperva-customers-protected-against-cve-2026-45247-in-mirasvit-full-page-cache-warmer-for-magento/>
- MITRE ATT&CK T1190 `Exploit Public-Facing Application`
- <https://attack.mitre.org/techniques/T1190/>
- MITRE ATT&CK T1505.003 `Server Software Component: Web Shell`
- <https://attack.mitre.org/techniques/T1505/003/>
- MITRE CWE-502 `Deserialization of Untrusted Data`
- <https://cwe.mitre.org/data/definitions/502.html>